

CAHIER DES CHARGES

Plateforme de supervision et de sécurisation du trafic réseau

Network Detection & Response · IDS/IPS · Gestion de trafic

Nom de l'application : SentiNet

Type de document	Cahier des charges fonctionnel et technique (CdCF/T)
Version	1.0 — Version initiale
Date	Juillet 2026
Statut	Pour validation
Classification	Diffusion restreinte — Interne
Périmètre	Sécurité réseau, supervision, réponse aux incidents

Document confidentiel — ne pas diffuser hors du périmètre autorisé

Sommaire

1. Présentation générale du projet

1.1 Contexte et enjeux

Les réseaux d'entreprise sont aujourd'hui exposés à une surface d'attaque en croissance continue : multiplication des équipements connectés, ouverture vers le cloud, télétravail, interconnexions avec des prestataires et des hébergeurs tiers. Dans le même temps, les techniques d'intrusion se sophistiquent (chaînes d'attaque multi-étapes, mouvements latéraux discrets, exfiltration chiffrée, canaux de commande et contrôle furtifs).

Les dispositifs périmétriques classiques (pare-feu, antivirus) ne suffisent plus à garantir l'intégrité du réseau. Il devient indispensable de disposer d'une visibilité complète et temps réel sur l'ensemble du trafic — nord/sud comme est/ouest — afin de détecter, qualifier et neutraliser les menaces au plus tôt, tout en maintenant la qualité de service pour les usages légitimes.

Constat de départ

Manque de visibilité sur le trafic interne (est/ouest) et sur les flux chiffrés.

Détection tardive des intrusions et temps de réponse (MTTD/MTTR) trop élevés.

Absence d'outil unifié combinant supervision, détection, réponse et gestion de la qualité de trafic.

Besoin de conformité (RGPD, directive NIS2, référentiels ANSSI, ISO/IEC 27001).

1.2 Objectif du projet

Le projet **SentiNet** vise à concevoir et déployer une plateforme logicielle unifiée, performante et hautement automatisée, permettant de :

- **Superviser** l'intégralité du trafic réseau en temps réel, jusqu'à la couche applicative (couche 7).
- **Détecter** l'ensemble des méthodes d'attaque et d'intrusion connues et inconnues (signatures, anomalies comportementales, apprentissage automatique).
- **Interagir** avec le réseau pour bloquer, isoler ou réorienter les flux malveillants, et fluidifier le trafic légitime (QoS, priorisation, équilibrage).
- **Répondre** automatiquement ou de manière semi-automatique aux incidents, afin de préserver l'intégrité, la confidentialité et la disponibilité du réseau.
- **Tracer et documenter** chaque événement à des fins d'investigation (forensics) et de conformité réglementaire.

1.3 Périmètre

Axe	Inclus dans le périmètre	Hors périmètre (V1)
Trafic	LAN, VLAN, DMZ, liaisons WAN/Internet, interconnexions data-center, flux est/ouest de virtualisation	Analyse en profondeur du contenu applicatif métier propriétaire non documenté
Couches OSI	Couches 2 à 7 (Ethernet → applicatif)	Analyse radio/spectre (Wi-Fi bas niveau, SDR)
Fonctions	Capture, DPI, détection, réponse, QoS, reporting, threat intelligence	EDR poste de travail (complémentaire, via intégration)
Déploiement	Mode passif (IDS/tap/SPAN) et mode en coupure (IPS inline)	Sécurité physique des équipements

1.4 Utilisateurs cibles

Profil	Attentes principales
Analyste SOC / N1-N2	Tri des alertes, investigation, qualification, réponse guidée.
Ingénieur sécurité / N3	Réglage des règles, threat hunting, forensics, tuning des modèles.
Administrateur réseau	Supervision des flux, QoS, dépannage de performance, cartographie.
RSSI / management	Tableaux de bord de synthèse, indicateurs de risque, reporting de conformité.
Administrateur de la plateforme	Gestion des comptes, des sondes, des mises à jour, de la haute disponibilité.

1.5 Glossaire et acronymes

Terme	Définition
NDR	Network Detection and Response — détection et réponse au niveau réseau.
IDS / IPS	Système de détection / de prévention d'intrusion (passif / en coupure).
DPI	Deep Packet Inspection — inspection approfondie du contenu des paquets.
DPDK / PF_RING	Bibliothèques de capture haute performance en espace utilisateur.
NetFlow / IPFIX / sFlow	Protocoles d'export de métadonnées de flux réseau.
SOAR	Security Orchestration, Automation and Response — orchestration de la réponse.
IoC / IoA	Indicateur de Compromission / d'Attaque.
MTTD / MTTR	Temps moyen de détection / de réponse.
MITRE ATT&CK	Base de connaissance des tactiques et techniques adverses.
QoS	Quality of Service — mécanismes de priorisation et de gestion de bande passante.

2. Objectifs détaillés et bénéfices attendus

Les objectifs sont exprimés de façon mesurable afin de servir de base à la recette et au suivi de performance de la solution.

Réf.	Objectif	Bénéfice	Indicateur cible
O1	Visibilité exhaustive du trafic réseau en temps réel	Suppression des angles morts	≥ 99,9 % des flux capturés
O2	Détection précoce des intrusions	Réduction de l'impact	MTTD < 60 s (signatures) ; < 5 min (anomalies)
O3	Réponse automatisée aux menaces	Confinement rapide	MTTR < 2 min sur incident critique
O4	Réduction du bruit d'alerte	Efficacité des analystes	Taux de faux positifs < 2 %
O5	Fluidification du trafic légitime	Qualité de service maintenue	Perte de paquets < 0,01 % en coupure
O6	Traçabilité et conformité	Auditabilité	100 % des événements horodatés et conservés
O7	Couverture des vecteurs d'attaque	Robustesse défensive	≥ 90 % des techniques MITRE ATT&CK pertinentes couvertes

3. Architecture générale de la solution

3.1 Vue d'ensemble

La solution repose sur une architecture modulaire et distribuée, organisée en quatre plans fonctionnels : un plan de capture (sondes), un plan d'analyse et de détection, un plan de données et de corrélation, et un plan de pilotage (interface et réponse). Cette séparation permet de faire évoluer et dimensionner chaque plan indépendamment.

Plan	Rôle	Composants techniques
Capture / acquisition	Interception et normalisation du trafic	Sondes réseau, TAP/SPAN, agents de flux (NetFlow/IPFIX)
Analyse / détection	Inspection, décodage, détection multi-moteur	Moteur de signatures, moteur d'anomalies, moteur ML, extraction de métadonnées
Données / corrélation	Stockage, indexation, corrélation d'événements	Bus de messages, base de séries temporelles, moteur de corrélation SIEM
Pilotage / réponse	Visualisation, alerting, remédiation	API, tableau de bord web, module SOAR, connecteurs (pare-feu, EDR, AD)

3.2 Modes de déploiement

3.2.1 Mode passif (IDS)

La sonde reçoit une copie du trafic via un port miroir (SPAN) ou un TAP réseau. Ce mode est non intrusif : il n'introduit aucune latence ni point de défaillance sur le chemin de données. Il sert à la détection, à l'observabilité et à l'investigation.

3.2.2 Mode en coupure (IPS inline)

La sonde est placée sur le chemin des paquets et peut abandonner (drop), réinitialiser (reset) ou réécrire un flux en temps réel. Ce mode autorise le blocage actif mais impose des exigences fortes de disponibilité (bypass matériel, mode fail-open/fail-close configurable) et de performance (latence maîtrisée).

Exigence d'architecture — EA-01

La solution doit permettre de mixer les deux modes selon les segments : passif sur les cœurs de réseau à fort débit, en coupure sur les points d'entrée sensibles (DMZ, accès Internet, interconnexions prestataires).

3.3 Principes directeurs d'architecture

- Scalabilité horizontale : ajout de sondes et de nœuds d'analyse sans interruption de service.
- Découplage par bus de messages : résilience aux pics de charge et absence de perte d'événements.
- Sécurité by design : chiffrement des communications inter-composants, cloisonnement, moindre privilège.
- Interopérabilité : API ouvertes, formats standards (STIX/TAXII, Syslog, JSON, IPFIX).
- Souveraineté et confidentialité : possibilité d'un déploiement entièrement on-premise, sans dépendance à un cloud externe.

4. Exigences fonctionnelles

Les exigences sont regroupées par module fonctionnel et identifiées par un code (EF-xx). Le niveau de priorité suit la méthode MoSCoW : M = indispensable (Must), S = souhaité (Should), C = confort (Could).

4.1 Module 1 — Capture et acquisition du trafic

Ce module constitue la fondation de la solution : il garantit qu'aucun flux pertinent n'échappe à l'analyse.

Réf.	Exigence	Prio.	Type
EF-101	Capter le trafic en mode promiscuité sur interfaces physiques et virtuelles (VLAN, VXLAN, trunk).	M	Fonct.
EF-102	Supporter la capture haute performance à 10/40/100 Gbps sans perte via DPDK / PF_RING.	M	Perf.
EF-103	Ingérer les métadonnées de flux exportées (NetFlow v5/v9, IPFIX, sFlow).	M	Fonct.
EF-104	Reconstituer et suivre les sessions TCP/UDP (suivi d'état, réassemblage des flux).	M	Fonct.
EF-105	Décapsuler les tunnels (GRE, IPsec transport visible, VXLAN, MPLS).	S	Fonct.
EF-106	Horodater chaque paquet avec précision (synchronisation NTP/PTP).	M	Fonct.
EF-107	Filtrer la capture (BPF) pour cibler des segments ou exclure des flux non pertinents.	S	Fonct.
EF-108	Assurer la capture continue avec buffering en cas de pic de charge (aucune perte).	M	Perf.

4.2 Module 2 — Inspection approfondie et décodage protocolaire

Réf.	Exigence	Prio.	Type
EF-201	Effectuer l'inspection approfondie des paquets (DPI) jusqu'à la couche 7.	M	Fonct.
EF-202	Décoder les principaux protocoles : HTTP(S), DNS, SMB/CIFS, RDP, SSH, TLS, FTP, SMTP, LDAP, Kerberos, ICMP.	M	Fonct.
EF-203	Identifier les applications indépendamment du port utilisé (détection applicative / fingerprinting JA3/JA4).	M	Fonct.
EF-204	Extraire les métadonnées des flux chiffrés sans déchiffrement (SNI, certificats, tailles, timing).	M	Fonct.
EF-205	Permettre l'inspection TLS déchiffrée sur les segments autorisés (bris de session maîtrisé, gestion des exclusions légales).	S	Fonct.
EF-206	Extraire les fichiers transférés pour analyse (hash, envoi vers sandbox/antivirus).	S	Fonct.
EF-207	Reconstruire les objets applicatifs (requêtes/réponses HTTP, requêtes DNS) pour investigation.	S	Fonct.

Point de vigilance juridique — Inspection TLS

L'interception déchiffrée du trafic doit respecter le cadre légal (RGPD, droit du travail, information des utilisateurs). Des règles d'exclusion (banque, santé, messagerie personnelle) doivent être configurables et documentées. Voir section 8 — Conformité.

4.3 Module 3 — Détection des menaces

La détection combine trois moteurs complémentaires afin de couvrir aussi bien les menaces connues que les comportements inconnus.

4.3.1 Détection par signatures

Réf.	Exigence	Prio.	Type
EF-301	Appliquer des règles de signatures ouvertes et compatibles (jeux de règles de type Suricata/Snort).	M	Fonct.
EF-302	Mettre à jour les jeux de règles automatiquement (flux d'abonnement + règles internes).	M	Fonct.
EF-303	Permettre la création, l'édition et le test de règles personnalisées.	M	Fonct.

4.3.2 Détection comportementale et par anomalies

Réf.	Exigence	Prio.	Type
EF-311	Établir une ligne de base (baseline) du comportement normal par hôte, service et segment.	M	Fonct.
EF-312	Détecter les écarts significatifs : volumétrie anormale, ports inhabituels, balayages, pics de connexions.	M	Fonct.
EF-313	Détecter les canaux de commande et contrôle (C2), le beaconing, le tunneling DNS/ICMP.	M	Fonct.
EF-314	Détecter les mouvements latéraux (accès inter-hôtes inhabituels, propagation SMB/RDP).	M	Fonct.
EF-315	Détecter les tentatives d'exfiltration (volumes sortants atypiques, destinations inconnues).	M	Fonct.

4.3.3 Détection par apprentissage automatique

Réf.	Exigence	Prio.	Type
EF-321	Intégrer des modèles de ML pour la détection d'anomalies non signaturées.	S	Fonct.
EF-322	Scorer chaque événement selon un niveau de risque (0-100) et le confronter au contexte.	S	Fonct.
EF-323	Permettre le réentraînement et l'ajustement des modèles sans interruption de service.	C	Fonct.
EF-324	Fournir une explicabilité minimale des alertes ML (facteurs contributifs).	S	Fonct.

4.4 Module 4 — Supervision et observabilité

Réf.	Exigence	Prio.	Type
EF-401	Fournir une cartographie dynamique du réseau et des flux (qui parle à qui, sur quoi).	M	Fonct.
EF-402	Afficher en temps réel : débit, latence, top talkers, top protocoles, sessions actives.	M	Fonct.
EF-403	Détecter et signaler les nouveaux équipements/hôtes apparaissant sur le réseau.	M	Fonct.
EF-404	Suivre la santé du réseau : pertes, retransmissions, saturation de liens, erreurs.	S	Fonct.
EF-405	Permettre le drill-down d'une vue macro jusqu'au paquet individuel.	S	Fonct.

Réf.	Exigence	Prio.	Type
EF-406	Historiser les métriques pour analyse de tendance et capacity planning.	S	Fonct.

4.5 Module 5 — Réponse, remédiation et interaction avec le réseau

Ce module matérialise la capacité à « prendre les mesures nécessaires à l'intégrité du réseau » : agir, et non seulement observer.

Réf.	Exigence	Prio.	Type
EF-501	Bloquer un flux ou un hôte malveillant en temps réel (drop/reset en mode inline).	M	Fonct.
EF-502	Mettre en quarantaine / isoler un hôte (via changement de VLAN, ACL, ou API de commutateur).	M	Fonct.
EF-503	Pousser dynamiquement des règles vers les pare-feu et équipements réseau (API/connecteurs).	M	Fonct.
EF-504	Déclencher des scénarios de réponse automatisés (playbooks SOAR) conditionnés au score de risque.	M	Fonct.
EF-505	Exiger une validation humaine (mode semi-automatique) pour les actions à fort impact.	M	Fonct.
EF-506	Journaliser toute action de réponse (qui/quoi/quand/pourquoi) de façon inaltérable.	M	Fonct.
EF-507	Permettre l'annulation (rollback) d'une action de réponse.	S	Fonct.
EF-508	Intégrer un dispositif anti-emballement (rate limiting des blocages, liste blanche des actifs critiques).	M	Fonct.
Garde-fou opérationnel — EF-508 Une réponse automatique mal calibrée peut provoquer un déni de service auto-infligé. La liste blanche des actifs critiques (contrôleurs de domaine, passerelles, serveurs métier) et les seuils de déclenchement sont obligatoires et versionnés.			

4.6 Module 6 — Fluidification et gestion de la qualité de trafic

Réf.	Exigence	Prio.	Type
EF-601	Classifier les flux par criticité métier et appliquer une politique de QoS (priorisation).	S	Fonct.
EF-602	Détecter et atténuer la congestion (traffic shaping, limitation de débit ciblée).	S	Fonct.
EF-603	Contribuer à l'atténuation DDoS (rate limiting, filtrage géographique/réputationnel, black-holing).	M	Fonct.
EF-604	Prioriser dynamiquement les flux légitimes lors d'une saturation ou d'une attaque volumétrique.	S	Fonct.
EF-605	Recommander des optimisations de trafic à partir de l'analyse historique.	C	Fonct.

4.7 Module 7 — Alerting, reporting et investigation (forensics)

Réf.	Exigence	Prio.	Type
EF-701	Générer des alertes qualifiées, dédoublées et corrélées (regroupement en incidents).	M	Fonct.
EF-702	Prioriser les alertes selon le risque, la criticité de l'actif et le contexte.	M	Fonct.

Réf.	Exigence	Prio.	Type
EF-703	Notifier via plusieurs canaux (interface, e-mail, Syslog, webhook, messagerie d'équipe).	M	Fonct.
EF-704	Conserver la capture complète (full packet capture) sur fenêtre glissante pour investigation.	S	Fonct.
EF-705	Reconstituer la chronologie d'un incident (timeline) et la chaîne d'attaque (kill chain).	M	Fonct.
EF-706	Exporter des rapports (PDF/CSV) : opérationnels, exécutifs et de conformité.	M	Fonct.
EF-707	Fournir des indicateurs (KPI) : MTTD, MTTR, volume d'alertes, taux de faux positifs.	M	Fonct.

4.8 Module 8 — Renseignement sur les menaces (Threat Intelligence)

Réf.	Exigence	Prio.	Type
EF-801	Ingérer des flux de renseignement au format STIX/TAXII et listes d'IOC.	M	Fonct.
EF-802	Enrichir automatiquement les alertes (réputation IP/domaine, géolocalisation, historique).	M	Fonct.
EF-803	Cartographier les détections sur le référentiel MITRE ATT&CK.	M	Fonct.
EF-804	Permettre l'ajout d'IOC internes et le partage vers d'autres plateformes.	S	Fonct.

4.9 Module 9 — Administration, contrôle d'accès et audit

Réf.	Exigence	Prio.	Type
EF-901	Gérer les comptes et les rôles (RBAC) avec principe du moindre privilège.	M	Fonct.
EF-902	S'intégrer à l'annuaire de l'entreprise (LDAP/Active Directory, SSO/SAML/OIDC).	M	Fonct.
EF-903	Imposer l'authentification multifacteur (MFA) pour les accès sensibles.	M	Sécu.
EF-904	Journaliser toutes les actions d'administration (piste d'audit inaltérable).	M	Sécu.
EF-905	Gérer le cycle de vie des sondes (enregistrement, mise à jour, supervision, révocation).	M	Fonct.
EF-906	Exposer une API REST/GraphQL documentée pour l'ensemble des fonctions.	M	Fonct.
EF-907	Permettre la configuration versionnée et le retour arrière des politiques.	S	Fonct.

5. Couverture des vecteurs d'attaque et d'intrusion

La solution doit détecter et, selon le mode de déploiement, contrer l'ensemble des grandes familles de techniques offensives. Le tableau ci-dessous met en correspondance chaque famille avec le mécanisme de détection attendu et la réponse associée. La couverture est alignée sur le référentiel MITRE ATT&CK Enterprise.

5.1 Cartographie menaces / détection / réponse

Famille d'attaque	Exemples de techniques	Mécanisme de détection	Réponse attendue
Reconnaissance	Balayage de ports, découverte réseau, énumération de services	Anomalie (fréquence/dispersion des connexions), signatures	Alerte, rate limiting, blocage de la source
Déni de service (DoS/DDoS)	Inondation SYN/UDP/ICMP, amplification, attaques applicatives L7	Volumétrie, seuils adaptatifs, réputation	Rate limiting, filtrage, black-holing, priorisation légitime
Interception (MITM)	ARP spoofing, DNS spoofing, rogue DHCP, détournement BGP	Anomalies L2/L3, incohérences ARP/DNS	Alerte, isolation de l'hôte, correction ACL
Accès par force brute	Brute force SSH/RDP/SMB, credential stuffing	Comptage d'échecs, motifs temporels, anomalie	Blocage temporaire, quarantaine, MFA
Exploitation de vulnérabilités	Exploits réseau, RCE, injection, dépassement de tampon	Signatures, décodage protocolaire, anomalies	Drop en coupure, alerte prioritaire
Logiciels malveillants	Diffusion, chargement, ransomware, ver	Signatures, extraction de fichiers, hash/sandbox	Blocage du flux, isolation, notification
Commande & contrôle (C2)	Beaconing, tunneling DNS/ICMP/HTTPS, domaines DGA	Comportement périodique, entropie, threat intel	Blocage domaine/IP, isolation de l'hôte
Mouvement latéral	Pass-the-hash, propagation SMB/RDP, exploitation interne	Corrélation inter-hôtes, anomalies est/ouest	Micro-segmentation, quarantaine
Exfiltration de données	Transferts massifs, canaux cachés, upload cloud non autorisé	Volumétrie sortante, destinations inconnues	Blocage, alerte, capture forensique
Menaces sur flux chiffrés	C2 en TLS, malware chiffré, DoH abusif	Fingerprint JA3/JA4, métadonnées, SNI, timing	Blocage réputationnel, inspection ciblée
Menace interne / abus	Accès inhabituels, escalade, usage hors politique	Baseline utilisateur, écarts comportementaux	Alerte, restriction d'accès, investigation

5.2 Exigence de couverture

Exigence — EF-CV-01

La solution doit couvrir au minimum 90 % des techniques MITRE ATT&CK Enterprise pertinentes pour un périmètre réseau, et fournir une matrice de couverture actualisée à chaque mise à jour majeure des règles et modèles.

Chaque nouvelle famille de menace identifiée doit pouvoir être adressée par ajout de règle, de modèle ou d'loC, sans redéploiement complet.

6. Exigences non fonctionnelles

6.1 Performance

Réf.	Exigence	Prio.	Cible
ENF-101	Débit d'analyse soutenu par sonde	M	≥ 10 Gbps sans perte
ENF-102	Latence ajoutée en mode coupure (IPS)	M	< 1 ms
ENF-103	Latence d'affichage d'une alerte critique	M	< 5 s après détection
ENF-104	Capacité d'ingestion d'événements	S	≥ 100 000 evts/s en pic
ENF-105	Temps de réponse de l'interface (95e centile)	S	< 2 s

6.2 Scalabilité et élasticité

- Ajout de sondes et de nœuds d'analyse à chaud, sans coupure de service.
- Architecture supportant la montée en charge de quelques dizaines à plusieurs milliers d'hôtes surveillés.
- Répartition de charge automatique entre nœuds d'analyse.

6.3 Disponibilité et résilience

Réf.	Exigence	Prio.	Cible
ENF-301	Disponibilité de la plateforme de gestion	M	≥ 99,9 %
ENF-302	Redondance des composants critiques (bases, corrélation, API)	M	Actif/actif ou actif/passif
ENF-303	Mode bypass matériel des sondes en coupure (fail-open/fail-close configurable)	M	Requis
ENF-304	Sauvegarde et restauration testée des configurations et données	M	RPO < 24 h / RTO < 4 h
ENF-305	Absence de perte d'événement en cas de pic (buffering/queue)	M	Requis

6.4 Sécurité de la solution elle-même

La plateforme de sécurité constitue une cible de choix : sa propre robustesse est une exigence de premier ordre.

- Chiffrement de bout en bout des communications inter-composants (TLS mutuel).
- Chiffrement des données au repos (captures, journaux, configurations).
- Durcissement des systèmes (hardening), surface d'attaque minimale, principe du moindre privilège.

- Piste d'audit inaltérable et signée pour toutes les actions sensibles.
- Gestion sécurisée des secrets (coffre-fort de secrets, rotation des clés).
- Processus de mise à jour de sécurité et suivi des vulnérabilités de la solution.

6.5 Ergonomie et exploitabilité

- Interface web responsive, claire, orientée analyste (réduction de la charge cognitive).
- Tableaux de bord personnalisables par profil et par rôle.
- Recherche rapide et filtres avancés sur les événements et flux.
- Documentation d'exploitation et aide contextuelle intégrée.
- Internationalisation : interface en français (langue principale) et en anglais.

6.6 Maintenabilité et évolutivité

- Architecture modulaire permettant l'ajout de moteurs de détection et de connecteurs.
- Mises à jour des règles et modèles sans interruption de service.
- Journalisation technique exploitable pour le diagnostic (observabilité de la solution).
- Déploiement reproductible (infrastructure as code, conteneurisation).

7. Contraintes techniques et environnement

7.1 Socle technologique recommandé

Le socle privilégie des briques éprouvées et, autant que possible, ouvertes, afin de garantir la maîtrise, l'auditabilité et l'absence d'enfermement propriétaire.

Domaine	Orientations technologiques recommandées
Capture haute perf.	libpcap, PF_RING, DPDK, AF_PACKET selon le débit ciblé
Moteurs de détection	Moteur de signatures type Suricata/Zeek ; moteurs d'anomalie et ML complémentaires
Traitement des flux	Bus de messages (type Kafka), traitement en flux (stream processing)
Stockage	Base de séries temporelles + moteur d'indexation/recherche ; stockage objet pour les captures
Backend / API	Services conteneurisés, API REST/GraphQL, orchestration (Kubernetes ou équivalent)
Frontend	Application web moderne (SPA), visualisations temps réel
Threat intel	Support STIX/TAXII, connecteurs vers plateformes de renseignement
Note Ces orientations sont indicatives : le prestataire peut proposer des alternatives équivalentes, sous réserve de démontrer le respect des exigences de performance, de sécurité et de souveraineté.	

7.2 Environnement de déploiement

- Déploiement on-premise prioritaire ; option hybride possible sans transfert de données sensibles hors du périmètre maîtrisé.
- Compatibilité avec des environnements virtualisés et physiques.
- Synchronisation temporelle fiable (NTP/PTP) obligatoire pour l'horodatage et la corrélation.
- Prise en compte des liaisons haut débit (10/40/100 Gbps) sur les cœurs de réseau.

7.3 Contraintes d'intégration à l'existant

- Intégration au SI de supervision et de ticketing en place (ITSM).
- Interopérabilité avec les pare-feu, commutateurs et équipements réseau du parc.
- Intégration à l'annuaire (Active Directory) pour l'authentification et le contexte.
- Export des événements vers un SIEM éventuel (Syslog, CEF, JSON).

8. Conformité réglementaire et cadre légal

La surveillance du trafic réseau touche à des données potentiellement personnelles. La conformité n'est pas une option : elle conditionne la légalité du dispositif.

Cadre	Exigences à respecter
RGPD	Minimisation des données, finalité déterminée, durée de conservation justifiée, information des personnes, registre des traitements, analyse d'impact (AIPD) si nécessaire.
Droit du travail (FR)	Information et consultation préalable des instances représentatives ; proportionnalité de la surveillance ; information des salariés.
Directive NIS2	Mesures de gestion des risques, détection et notification des incidents pour les entités concernées.
Référentiels ANSSI	Alignement sur les bonnes pratiques (journalisation, cloisonnement, PSSI).
ISO/IEC 27001	Contribution au SMSI : traçabilité, gestion des incidents, contrôle d'accès.
Exigence — Conformité	
La solution doit fournir des mécanismes natifs de gestion de la conservation (rétention paramétrable, purge automatique), d'anonymisation/pseudonymisation, et de cloisonnement des accès aux données sensibles, avec journalisation des consultations.	

9. Intégrations et interopérabilité

Catégorie	Intégrations attendues
Équipements réseau	Pare-feu, commutateurs, routeurs (API/CLI) pour blocage et quarantaine dynamiques.
Annuaire & IAM	Active Directory / LDAP, SSO (SAML/OIDC), MFA.
SIEM / log management	Export Syslog/CEF/JSON, corrélation croisée.
EDR / postes	Corrélation réseau ↔ endpoint, isolation coordonnée.
ITSM / ticketing	Création automatique de tickets d'incident, suivi du cycle de vie.
Threat intelligence	STIX/TAXII, plateformes de renseignement, listes d'IoC.
Notification	E-mail, webhooks, messagerie d'équipe (chat), Syslog.
Sandbox / antivirus	Analyse des fichiers extraits, vérification de hash/réputation.

Toutes les intégrations doivent s'appuyer sur des API documentées, versionnées et sécurisées (authentification, chiffrement, limitation de débit).

10. Démarche projet, phases et livrables

Le projet est conduit de façon itérative, chaque phase produisant des livrables validables et une valeur exploitable.

Phase	Intitulé	Contenu	Livrables
P0	Cadrage & conception	Ateliers, architecture détaillée, choix technologiques, cartographie des flux	Dossier d'architecture, plan de projet
P1	Socle & capture	Déploiement des sondes, capture, observabilité de base	Sondes opérationnelles, tableau de bord de flux
P2	Détection	Signatures, anomalies, threat intel, corrélation	Moteurs de détection, matrice ATT&CK
P3	Réponse & QoS	Playbooks, connecteurs de blocage, gestion de trafic	Module de réponse, connecteurs, garde-fous
P4	Industrialisation	Haute disponibilité, montée en charge, durcissement, conformité	Environnement de production, dossier de sécurité
P5	Recette & TdB	Tests fonctionnels, tests de charge, simulation d'attaques (red team)	PV de recette, rapport de tests
P6	Exploitation	Transfert de compétences, documentation, run	Documentation, formation, contrat de maintenance

10.1 Livrables documentaires attendus

- Dossier d'architecture technique et de sécurité.
- Documentation d'installation, d'exploitation et d'administration.
- Guide utilisateur par profil (analyste, admin réseau, RSSI).
- Matrice de couverture MITRE ATT&CK.
- Plan de reprise/continuité et procédures de sauvegarde.
- Registre de conformité (RGPD, rétention, accès).

11. Critères de recette et indicateurs de succès

La solution est réputée conforme si l'ensemble des critères ci-dessous sont satisfaits lors de la recette, tests de charge et simulation d'attaques inclus.

Réf.	Critère de recette	Seuil d'acceptation
R1	Taux de capture du trafic sur segments supervisés	≥ 99,9 %
R2	Détection des scénarios d'attaque du plan de test	100 % des scénarios critiques détectés
R3	Temps moyen de détection (MTTD)	< 60 s (signatures), < 5 min (anomalies)
R4	Temps moyen de réponse automatisée (MTTR)	< 2 min sur incident critique
R5	Taux de faux positifs après tuning	< 2 %
R6	Latence ajoutée en mode coupure	< 1 ms
R7	Absence de perte de paquets en coupure	< 0,01 %
R8	Couverture MITRE ATT&CK pertinente	≥ 90 %
R9	Disponibilité de la plateforme sur période de test	≥ 99,9 %
R10	Traçabilité et conformité des journaux	100 % des événements horodatés et conservés

11.1 Simulation d'attaques (validation par la preuve)

La recette de sécurité inclut une campagne de tests offensifs contrôlés (red team / purple team) couvrant chaque famille du chapitre 5 : reconnaissance, DoS/DDoS, MITM, force brute, exploitation, malware, C2, mouvement latéral et exfiltration. Chaque scénario doit être détecté, qualifié, et — sur les segments en coupure — bloqué, avec production automatique de la chronologie de l'incident.

Annexe A — Récapitulatif des priorités

Priorité (MoSCoW)	Signification	Traitement
M — Must	Indispensable au fonctionnement et à la valeur cible	Obligatoire pour la mise en production
S — Should	Forte valeur, contournement possible à court terme	Planifié sur les premières itérations
C — Could	Confort, valeur additionnelle	Selon budget et calendrier

Annexe B — Nom de l'application

Le nom retenu pour l'application est SentiNet, contraction de « sentinelle » et « network / net ». Il évoque directement la fonction de la solution : une sentinelle en veille permanente sur le réseau, qui surveille, alerte et protège.

- **SentiNet** — nom retenu (sentinelle + réseau).
- Autres pistes envisagées : *VIGIENET*, *ARGUS*, *NETWATCH*.

— Fin du cahier des charges —